

HUM34-3

Digital Threats & Cybersecurity

Threats, actors, influence operations, and the governance of cyber risk

Cybersecurity as a governance, risk, and institutional challenge.

Albert School — 12 hours

Preface

This is the second Law & Regulation course. It shifts from legal fundamentals to the domain where institutional architecture confronts adversarial reality: cybersecurity is treated here not as a technical subject but as a governance, risk, and institutional challenge — threat actors, institutional responses, and the ethical and legal tensions those responses create. The course builds on HUM24-2's regulatory architecture (GDPR, EU AI Act, DSA/DMA) and assumes it; the concurrent Geopolitics course supplies the state-actor context. The objective is analysis readable by a non-technical decision-maker.

Contents

Preface	2
1 Cybersecurity threat taxonomy	2
2 The attack surface	2
3 Zero-day vulnerabilities and the exploit market	3
4 Cybersecurity actors	3
5 Disinformation vs. misinformation	3
6 Information sovereignty	3
7 Risk assessment for digital assets	4
8 The legal and regulatory architecture of cybersecurity	4
9 Cyber conflict as geopolitical instrument	4
10 Incident briefing	4

1 Cybersecurity threat taxonomy

The main categories of cybersecurity threat, each with a named incident:

- **Malware:** malicious software that runs on a target system to damage, exfiltrate, or control it. *Incident: the NotPetya malware (2017), which spread globally and caused damage across multiple firms.*
- **Phishing:** deceptive messages that trick a person into revealing credentials or running malicious content; the attack targets the human, not the machine. *Incident: the phishing of campaign credentials in the 2016 US election breaches.*
- **Ransomware:** malware that encrypts a victim's data and demands payment for its release. *Incident: NHS WannaCry (2017), which disrupted hospital operations across the UK.*
- **DDoS** (distributed denial of service): flooding a service with traffic from many sources so that it becomes unavailable to legitimate users. *Incident: the Mirai botnet attack on the Dyn DNS provider (2016), which took down major websites.*
- **Supply chain compromise:** attacking an organisation indirectly by compromising a trusted supplier or software dependency. *Incident: SolarWinds (2020), where malicious code inserted into a software update reached thousands of downstream organisations.*

2 The attack surface

An organisation's **attack surface** is the set of points through which it can be attacked. Analysing it means separating three kinds of factor:

- **Technical:** software vulnerabilities, exposed services, unpatched systems, insecure configurations.
- **Organisational:** weak processes, unclear responsibilities, inadequate access controls, poor supplier management.
- **Human:** people who can be deceived (phishing), make errors, or misuse access.

A vulnerability assessment that looks only at the technical layer misses the organisational and human factors, which are frequently the ones actually exploited.

3 Zero-day vulnerabilities and the exploit market

A **zero-day vulnerability** is a flaw unknown to the party responsible for fixing it, so no patch exists and defenders have had “zero days” to respond. An **exploit** is code that takes advantage of a vulnerability; zero-day exploits are bought and sold in an **exploit market** whose buyers include criminals, governments, and brokers.

This market creates ethical and legal tensions. The central one is the **stockpile-versus-disclose dilemma**: when a state discovers a zero-day, it can **disclose** it so the flaw is fixed and everyone is made safer, or **stockpile** it for its own intelligence or offensive use, leaving the flaw open — and exploitable by others if it leaks. The EternalBlue exploit, developed and stockpiled and then leaked, was reused in WannaCry, illustrating the cost of the stockpile choice.

4 Cybersecurity actors

The main actors differ in their motivations and methods:

- **State actors** (advanced persistent threats, APTs): well-resourced groups acting for a state, pursuing espionage, sabotage, or strategic advantage over long periods. *Case: the SolarWinds intrusion attributed to a state actor.*
- **Criminal organisations**: profit-driven groups running ransomware, fraud, and data theft, increasingly as a service. *Case: the DarkSide group behind the Colonial Pipeline ransomware attack (2021).*
- **Hacktivists**: actors pursuing a political or ideological cause through defacements, leaks, or DDoS.
- **Private security firms**: legitimate companies that defend organisations (incident response, threat intelligence) — and, in some cases, firms that develop and sell offensive tools.

5 Disinformation vs. misinformation

- **Misinformation** is false or misleading information spread **without intent to deceive** — the sharer may believe it is true.
- **Disinformation** is false or misleading information spread **deliberately** to deceive or manipulate, typically as part of an organised **influence operation**.

The mechanics of an influence operation can be analysed along four dimensions:

1. **Production**: who creates the content and the false narrative.
2. **Distribution**: the channels and amplification (fake accounts, bots, paid promotion) used to spread it.
3. **Intended audience**: the specific population the operation targets.
4. **Measurable effects**: the observable impact — reach, engagement, and any change in behaviour or opinion.

6 Information sovereignty

Information sovereignty is a state’s claim to control the data flows, platform content, and digital infrastructure within or affecting its territory. States pursue it to protect national security, to regulate what their populations see, and to keep critical data and infrastructure under domestic control.

It connects directly to the HUM24-2 regulatory architecture: **GDPR** governs where and how personal data may be processed and transferred; the **DSA** imposes obligations on platforms over content; the **DMA** constrains gatekeeper platforms; and the **EU AI Act** governs AI systems by risk tier. Together these are instruments through which the EU asserts a form of information sovereignty over its digital space.

7 Risk assessment for digital assets

A basic risk assessment for a specific digital asset proceeds by identifying:

1. **Probable threat actors**: which of the actors above would plausibly target this asset, and why.
2. **Attack vectors**: the technical, organisational, and human paths by which they could reach it.
3. **Proportionate mitigations**: defences matched to the likelihood and impact of each risk — neither under- nor over-investing.
4. **Applicable regulatory framework**: the obligations that apply, in particular **GDPR 72-hour breach notification** and, where relevant, **NIS2** resilience obligations.

The output must be suitable for a **non-technical decision-maker**: it states the risks, their likelihood and impact, and the proposed mitigations in plain terms.

8 The legal and regulatory architecture of cybersecurity

Cybersecurity is governed by a set of agencies and rules:

- **ANSSI**: the French national cybersecurity agency.
- **ENISA**: the European Union Agency for Cybersecurity.
- **CISA**: the US Cybersecurity and Infrastructure Security Agency.
- **GDPR breach notification**: a personal-data breach must be notified to the supervisory authority within **72 hours** of becoming aware of it.
- **NIS2**: the EU directive imposing **resilience obligations** (risk management, incident reporting) on operators of essential and important services.

These bodies set standards, coordinate response, and enforce obligations — but responsibility is split across national and EU levels and across agencies, and there are **gaps**: actors operating from outside a jurisdiction, assets that fall under no clear regulator, and obligations that are unevenly enforced.

9 Cyber conflict as geopolitical instrument

Cyber operations are an instrument of state strategy: states use them for espionage, coercion, sabotage of critical infrastructure, and influence operations, often below the threshold of open armed conflict. This intersects with **international norms**, which remain contested — there is no settled agreement on what counts as an act of war in cyberspace or on the limits of acceptable state behaviour. A cyber incident therefore has to be read not only as a technical event but as part of a named state's cybersecurity strategy.

10 Incident briefing

The course's integrative task is a **written briefing on a real cybersecurity incident** (SolarWinds, Colonial Pipeline, NHS WannaCry, Uber 2022, or equivalent). A briefing identifies:

1. the **vulnerability exploited**;
2. the **institutional failures** that enabled it (technical, organisational, human);

3. the **measured impact**;
4. the **lessons for organisational practice**;

and connects the incident's logic to a **named state's cybersecurity strategy**.